PROJET SPÉCIALITÉ CYBERSÉCURITÉ

Analyse EBIOS RM, Simulations d'attaques et Plan de sécurisation

TechnoSite Industrie — Robotique de précision

Réalisé par Clément VAN MELKEBEKE et MOUMOU idir

1. Introduction et contexte

L'entreprise TechnoSite Industrie, spécialisée dans la robotique de précision, exploite un site de production automatisé intégrant des systèmes IT, une zone OT, un SCADA cloud, des caméras IP/RFID et une application web de maintenance exposée sur Internet. Une liaison VPN relie le site au siège.

Plusieurs incidents récents ont été détecté anomalies réseau OT, connexions suspectes sur le firewall et campagne de phishing. C'est ce qui motivent cette mission d'audit.

Zone	Composants	Protocoles	Risques majeurs
IT	AD, ERP, mails, PC	TCP/IP, HTTPS, SMB	Phishing, ransomware, fuite données
OT	PLC S7-1500, robots, capteurs	Modbus/TCP, MQTT	Sabotage consignes, arrêt production
Cloud SCADA	Supervision distante	HTTPS, API REST	Compromission serveur cloud
Physique	Caméras IP, badges RFID	HTTP, SNMP	Intrusion physique, clonage badge
VPN	Tunnel OpenVPN/IPSec	UDP/1194	Accès distant non maîtrisé

Tableau 1 — Architecture simplifiée du SI

2. Analyse de risques EBIOS RM

2.1 Cadrage et socle de sécurité

Continuité de production (D4), intégrité des consignes PLC (I4), données de conception (C3), données clients/ERP (C3). Périmètre : réseaux IT/OT, cloud SCADA, accès physique.

Socle existant : segmentation VLANs partielle (pas de DMZ), pas de MFA, pas de SIEM, sauvegarde sur NAS sans air-gap, MQTT non chiffré, aucune formation anti-phishing.

2.2 Sources de risques

Source	Motivation	Capacité	Vraisemblance
Cybercriminel	Gain financier (rançon)	Moyenne	Élevée
Concurrent industriel	Espionnage économique	Élevée	Moyenne
Insider (salarié)	Revanche / profit	Moyenne	Moyenne
Groupe APT (étatique)	Cyber-espionnage SCADA	Très élevée	Faible
Prestataire (supply chain)	Compromis par un tiers	Variable	Moyenne

Tableau 2 — Sources de risques

2.3 Scénarios stratégiques

Scénario	Bien visé	Impact
Sabotage PLC via pivot IT→OT	Production / Intégrité	Arrêt production, dommages physiques
Exfiltration données conception	Propriété intellectuelle	Perte avantage concurrentiel

Scénario	Bien visé	Impact
Ransomware IT + SCADA	Production / Données	Arrêt complet, rançon, perte données
Intrusion physique (badge cloné)	Sécurité physique	Accès non autorisé, sabotage

Tableau 3 — Scénarios stratégiques

2.4 Scénario opérationnel

Phase	Action attaquant	Outils	Détection
1. Reconnaissance	Scan Nmap, Shodan, WHOIS	Nmap, Shodan	Alertes IDS, pics DNS
2. Livraison	Spear phishing (faux mail IT)	GoPhish, SET	Anti-spam, réputation URL
3. Exploitation	Vol credentials AD via faux SSO	Evilginx2	Connexion IP inhabituelle
4. Installation	Reverse shell sur poste IT	Metasploit, Cobalt Strike	Alerte EDR
5. Pivot IT→OT	Mouvement latéral via creds AD	Mimikatz, SSH tunnel	Firewall IT-OT, logs AD
6. Sabotage	Écriture Modbus registre PLC	pymodbus, Snap7	IDS OT, alerte SCADA

Tableau 4 — Kill chain du scénario SS-01 (MITRE ATT&CK;)

2.5 Cartographie des risques

Scénario	Gravité	Vraisemblance	Criticité	Niveau
Sabotage PLC	4	3	12	**CRITIQUE**
Ransomware	4	3	12	**CRITIQUE**
Exfiltration	3	3	9	**ÉLEVÉ**
Intrusion physique	3	2	6	MOYEN

Tableau 5 — Cartographie des risques (G x V)

3. Simulations d'attaques

Scénario	Objectif	Outils	Preuve
1. Phishing ciblé	Mesurer taux de clic techniciens	GoPhish, SET	Dashboard GoPhish, export CS
2. Scan réseau	Cartographier ports/services	Nmap, Nessus, Shodan	Rapport Nmap XML, rapport Nessus
3. Exploitation web	SQLi / XSS sur app maintenance	Burp Suite, SQLMap	Captures Burp, logs SQLMap
4. Pivot IT→OT	Mouvement latéral vers PLC	Metasploit, Mimikatz, pymodbus	Captures Wireshark Modbus, screenshots
5. Ransomware simulé	Tester résilience sauvegarde	Script PowerShell (AES-256)	Logs script, chronologie
6. Exfiltration MQTT	Interception flux IoT en clair	Wireshark, mosquitto_sub	PCAP Wireshark, logs mosquitto

Tableau 6 — Synthèse des simulations d'attaques

3.1 Focus — Pivot IT vers OT (scénario critique)

Ce scénario démontre le risque le plus élevé qu'un attaquant compromet un poste IT via phishing, extrait les credentials AD, pivote vers le réseau OT via SSH tunnel, puis modifie les registres Modbus.

3.2 Focus — Analyse des journaux

Les journaux simulés (firewall, AD, Modbus, MQTT) révèlent une chronologie d'attaque cohérente, par exemple : accès VPN depuis le Vietnam, brute force AD, création de compte admin, connexion MQTT non autorisée, écriture Modbus anormale, exfiltration de données. .

4. Plan de sécurisation global

Le plan suit une logique de **défense en profondeur** avec priorisation par rapport impact/effort.

4.1 Mesures techniques

Couche	Mesure	Description	Priori
Réseau	Micro-segmentat ion	VLANs IT(10)/OT(20)/DMZ(30)/IoT(40)/Mgmt(99), firewall NG interzone	P1
Réseau	IDS industriel	Suricata/Nozomi sur segment OT, règles Modbus/TCP spécifiques	P1
Identité	MFA généralisé	TOTP/FIDO2 sur VPN, admin, app web, SCADA (Keycloak)	P1
Identité	Tiering model AD	Tier 0/1/2, PAW, LAPS, suppression comptes dormants	P2
Endpoint	EDR/XDR	CrowdStrike ou Defender for Endpoint sur IT, alerting temps réel	P1
Données	MQTTS + TLS	Migration MQTT port 8883 avec certificats client, TLS 1.3 partout	P2
Supervisio n	SIEM + SOC	Wazuh/ELK, 12 règles de corrélation, centralisation logs	P2
Application	WAF	ModSecurity/Cloudflare devant app maintenance, OWASP hardening	P1
Sauvegard e	3-2-1 air-gap	3 copies, 2 supports, 1 hors site, test restauration trimestriel	P1
OT	Hardening PLC	Firmware à jour, auth Siemens, ACL IP Modbus, désactivation services	P2

Tableau 7 — Mesures techniques

4.2 Mesures organisationnelles

Domaine	Mesure	Description	Priori té
Sensibilisatio n	Anti-phishing	Campagnes GoPhish trimestrielles, formation obligatoire	P1
Gouvernanc e	PSSI	Politique conforme ISO 27001, charte informatique, gestion accès	P1
Incident	Plan réponse (PRI)	Fiches réflexes par type, exercice crise annuel, post-mortem	P1
Accès	Revue trimestrielle	Audit comptes AD/OT, suppression dormante, moindre privilège	P2
Tiers	Risque fournisseurs	Questionnaire sécurité, clauses contractuelles, VPN dédié + MFA	P2
Conformité	Audit annuel	IEC 62443 (OT) + ISO 27001 (IT), plan Amélioration continue	P3

Tableau 8 — Mesures organisationnelles

4.3 Priorisation et budget

Horizon	Actions clés	Délai	Budget
P1 — Quick Wins	MFA, sauvegarde 3-2-1, segmentation, EDR, WAF, anti-phishing	0-3 mois	15-25 k EUR
P2 — Consolidation	SIEM, tiering AD, MQTTS, hardening PLC, IDS OT, revue accès	3-6 mois	30-50 k EUR
P3 — Maturité	Audit ISO/IEC, SOC 24/7, Zero Trust, cyber-assurance	6-12 mois	50-100 k EUR

Tableau 9 — Priorisation des actions

5. Plan de réponse à incident

Le plan de réponse à incident (PRI) définit les procédures à suivre en cas d'incident de sécurité, avec des fiches réflexes adaptées à l'environnement IT/OT.

5.1 Processus global

Phase	Actions	Responsable	Délai cible
1. Détection	Alerte SIEM/EDR/IDS, signalement utilisateur, monitoring SCADA	SOC / Équipe IT	Immédiat
2. Qualification	Évaluation de la sévérité (P1-P4), identification du périmètre touché	RSSI / SOC	< 15 min
3. Confinement	Isolation réseau du segment affecté, blocage IP/compte, coupure VPN	IT + OT	< 30 min
4. Éradication	Suppression du malware, réinitialisation credentials, patching	IT + Prestataire	< 4h
5. Restauration	Restauration depuis backup vérifié, validation intégrité PLC	IT + OT	< 8h (RTO)
6. Post-mortem	Analyse root cause, rapport, mise à jour des règles SIEM, retex	RSSI	< 5 jours

Tableau 10 — Processus de réponse à incident

5.2 Fiches réflexes

Fiche A — Ransomware

- Confinement : Déconnecter immédiatement le segment IT du réseau.
- Éradication : Scanner tous les postes avec EDR. Réinitialiser tous les mots de passe AD.
- Restauration : Restaurer depuis la copie air-gap. Vérifier les checksums. Tester les PLC avant remise en production.

Fiche B — Compromission OT / PLC

- Confinement : Isoler le PLC compromis du réseau Modbus. Alerter le responsable production.
- Restauration : Recharger la configuration PLC validée.

Fiche C — Phishing avec compromission de compte

- Confinement : Réinitialiser le mot de passe du compte compromis. Révoquer les sessions actives. Bloquer le domaine de phishing au proxy.
- Éradication : Scanner le poste de la victime (EDR). Vérifier les boîtes mail pour des règles de transfert malveillantes. Auditer les connexions du compte.
- Restauration : Activer le MFA sur le compte. Sensibiliser l'utilisateur.

6. Architecture sécurisée cible

L'architecture cible repose sur 6 zones de sécurité séparées par des points de contrôle, selon le principe de défense en profondeur.

Zone	VLAN	Composants	Contrôles	Monitoring
DMZ	30	WAF, reverse proxy, app web	FW NG, IPS, anti-DDoS	Logs WAF, SIEM
IT	10	AD, ERP, mails, postes	MFA, GPO durcies, EDR	SIEM, EDR, AD audit
OT	20	PLC, robots, HMI	FW industriel, ACL Modbus	IDS industriel
IoT	40	Capteurs, broker MQTTS	Certificats TLS, ACL topics	Anomalies capteurs
Cloud	Ext.	SCADA supervision, API	VPN S2S, mutual TLS	Logs API
Mgmt	99	PAW admin, SIEM, backup	MFA + certificat, accès restreint	Audit sessions

Tableau 11 — Architecture cible par zone

7. Conclusion

L'analyse EBIOS RM a identifié 4 scénarios stratégiques dont 2 critiques (sabotage PLC et ransomware, criticité 12/16). Les simulations confirment la faisabilité technique de chaque scénario : segmentation IT-OT insuffisante, absence de MFA, protocoles non chiffrés.

.